Semana 06 — Hardening, firewall y detección

Fase 3: Defensa y hardening — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	06 de 10
Fase	3 — Defensa y hardening
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Actividad formativa
Entrega	GitHub, carpeta semana_06/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_06 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: systemd-analyze security, fail2ban, openssh, Suricata, ubuntu 24.04, nftables, ufw.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

> Aplicar endurecimiento de sistemas, configurar filtrado por defecto y comprobar la detección con Suricata.

3 Contenidos que se aplican

- Mínimo privilegio, usuarios del sistema y política de sudo.
- Permisos SUID, SGID y archivos con escritura global.
- SSH con claves, desactivación de contraseña y fail2ban.
- Parcheo, servicios innecesarios y CIS Benchmarks.
- Endurecimiento de systemd y perfiles de AppArmor.
- Línea base medible y verificación posterior.
- Política por defecto, nftables/ufw y segmentación.
- IDS/IPS con Suricata, firmas y lectura de alertas.
- TLS en tránsito y verificación de certificados.
- Comprobar que la detección ve el ataque frenado por la política.

4 Escenario

> Cada grupo endurece el contenedor, aplica política de filtrado, repite el escaneo y analiza las alertas de Suricata.

5 Paso a paso de la práctica

1. Documentar el estado inicial de doce controles antes de cambiar nada.
2. Aplicar los cambios de endurecimiento y reiniciar los servicios afectados.
3. Aplicar la política de filtrado en deny por defecto y permitir solo lo necesario.
4. Repetir el escaneo, verificar qué puertos dejaron de responder y clasificar las alertas de Suricata.
5. Justificar las excepciones de hardening y proponer una regla de detección específica.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_06/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: systemd-analyze security, fail2ban, openssh, Suricata, ubuntu 24.04, nftables, ufw.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 2	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.
Grupo 3	**Rojo**	Evidencia cruda en semana_06/evidencia y el apartado de reproducción del informe.
Grupo 4	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.

7 Qué se entrega

Auditor propio, hardening antes/después, reglas de firewall, comparativa de alcance y alertas de Suricata clasificadas.

Estructura de la carpeta `semana_06/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_06/informe.md o informe.pdf con el entregable de esa práctica.
- semana_06/scripts/ con el código, con type hints y docstrings.
- semana_06/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_06/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.

- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Doce controles documentados y verificables	2,0
Auditor funcional con veredicto por control	2,0
Política de filtrado correcta y sistema operativo	2,5
Alertas de Suricata clasificadas y regla propuesta	2,5
Antes/después comparables y justificación de excepciones	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_06/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 06: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Mínimo privilegio	Cada cuenta, servicio y proceso tiene solo los permisos necesarios para su función.
SUID	Bit que hace que un ejecutable corra con los permisos de su propietario. Un SUID mal configurado es una vía de elevación.
CIS Benchmarks	Guías de configuración segura con comprobaciones concretas por sistema y servicio. Sirven para construir la línea base.
AppArmor	Módulo del kernel que confina un programa a los archivos y capacidades que declara su perfil.
Línea base	Estado medido y documentado de una configuración. Sin ella no se puede demostrar que el endurecimiento cambió algo.
nftables	Framework de filtrado del kernel que sustituye a iptables. ufw es una interfaz simplificada sobre él.
IDS/IPS	Sistema que detecta (IDS) o bloquea (IPS) tráfico y comportamiento según firmas o reglas.
Suricata	Motor IDS/IPS de código abierto con firmas y extracción de eventos. Sus alertas se leen, no solo se cuentan.